KYC (Know Your Customer) Policy & Procedure Manual

FinTech Compliance Department - Internal Reference v2.1

1. Introduction to KYC

Know Your Customer (KYC) is a mandatory compliance process used by financial institutions to verify the identity of their clients and assess potential risks of illegal intentions for the business relationship. KYC is a critical component of Anti-Money Laundering (AML) and Counter-Terrorism Financing (CTF) frameworks globally.

KYC processes help institutions:

- Verify customer identity
- Understand the nature of the customer's activities
- Assess money laundering and terrorist financing risks
- Comply with regulatory requirements (FATF, FinCEN, FCA, RBI, etc.)

2. Customer Identification Program (CIP)

The Customer Identification Program (CIP) is the first step in KYC. It requires collecting and verifying basic identifying information about every customer before establishing a business relationship.

2.1 Required Information

For Individual Customers:

- Full legal name
- Date of birth
- Residential address
- Government-issued ID number (Passport, National ID, Driver's License)
- Tax Identification Number (TIN) or equivalent

For Corporate Customers (Legal Entities):

- Registered company name
- Registration number and jurisdiction
- Registered address and principal place of business
- Nature of business and industry sector
- Ultimate Beneficial Owners (UBOs) - individuals owning >25% stake

2.2 Document Verification

Acceptable identity documents include:

1. **Tier 1 (Strongest)**: Passport, National Identity Card
2. **Tier 2 (Standard)**: Driver's License, Voter ID, Residence Permit
3. **Tier 3 (Supplementary)**: Utility bills, Bank statements (for address proof only)

All documents must be:

- Valid and not expired
- Clear and legible (no obscured information)
- Verified against authoritative databases where possible

---

3. Customer Due Diligence (CDD)

Customer Due Diligence is the ongoing process of gathering and verifying information about customers to understand their risk profile.

3.1 Standard Due Diligence (SDD)

Applied to low-risk customers. Requires:

- Basic identity verification (CIP)
- Understanding the purpose and intended nature of the relationship
- Ongoing monitoring at a reduced frequency (annual review)

3.2 Enhanced Due Diligence (EDD)

Applied to high-risk customers including:

- Politically Exposed Persons (PEPs)
- Customers from high-risk jurisdictions (FATF grey/black list countries)
- Customers with unusual transaction patterns
- Customers in high-risk industries (cryptocurrency, arms, gambling)

EDD requirements:

- Senior management approval for onboarding
- Source of funds verification
- Source of wealth documentation
- Quarterly or semi-annual reviews
- Adverse media screening
- Sanctions list screening (OFAC, UN, EU, HMT)

3.3 Simplified Due Diligence (SimplDD)

May be applied to certain low-risk products and customer categories:

- Government entities
- Listed public companies on regulated exchanges
- Regulated financial institutions in low-risk jurisdictions

---

4. Risk Assessment Framework

4.1 Risk Categories

Low Risk Indicators:

- Resident customers with stable employment
- Transactions consistent with declared business activity
- Long-standing relationship with no suspicious activity
- Customers from low-risk jurisdictions

Medium Risk Indicators:

- New customers with limited history
- Customers from medium-risk jurisdictions
- Business with limited public information
- Cash-intensive businesses (restaurants, retail)

High Risk Indicators:

- PEPs and their family members/close associates
- Non-face-to-face onboarding without strong digital verification
- Customers from FATF-listed high-risk jurisdictions
- Complex corporate structures with unclear beneficial ownership
- Industries: cryptocurrency exchanges, money service businesses, shell companies

4.2 Risk Scoring Model

Risk scores are calculated using a weighted model:

```
Factor  |  Weight
Customer type (individual/corporate)  |  20%
Geographic risk  |  25%
Industry/sector risk  |  20%
Transaction behavior  |  20%
Adverse media / sanctions  |  15%
```

Total score 0-40: Low Risk -> Standard CDD + Annual Review

Total score 41-70: Medium Risk -> Enhanced monitoring + Semi-annual Review

Total score 71-100: High Risk -> EDD required + Quarterly Review

---

5. Politically Exposed Persons (PEPs)

A Politically Exposed Person (PEP) is an individual who holds or has held a prominent public function domestically or in a foreign country.

5.1 PEP Categories

Domestic PEPs: Current or former holders of prominent public functions within the country

- Heads of state and government
- Senior politicians and party officials
- Senior judicial officers
- Senior military officers
- Senior executives of state-owned enterprises

Foreign PEPs: Same categories but in a foreign country - generally higher risk

International Organization PEPs: Senior management of international organizations (UN, IMF, World Bank)

5.2 PEP Screening Process

1. Screen all customers against PEP databases at onboarding
2. Apply EDD to all identified PEPs regardless of risk score
3. Obtain senior management sign-off
4. Verify source of funds and wealth
5. Conduct ongoing monitoring with quarterly reviews
6. Screen associated family members and close associates

---

6. Sanctions Screening

All customers must be screened against major sanctions lists:

- **OFAC (US)**: Office of Foreign Assets Control - SDN List
- **UN**: United Nations Consolidated Sanctions List
- **EU**: European Union Restrictive Measures
- **HMT (UK)**: His Majesty's Treasury Financial Sanctions
- **INTERPOL**: Red Notices

6.1 Screening Frequency

- At onboarding (mandatory)
- At each transaction above threshold ($10,000 or local equivalent)
- Real-time for high-risk customers
- Daily batch screening for medium/low risk customers
- Immediately upon new sanctions list publications

6.2 Match Handling

True Match -> Immediate freeze of account, file Suspicious Activity Report (SAR), notify compliance officer
Possible Match -> Escalate to compliance team within 24 hours for manual review
No Match -> Proceed with onboarding/transaction

---

7. Transaction Monitoring

7.1 Monitoring Rules

The transaction monitoring system flags transactions based on:

- **Large Cash Transactions**: Single transactions >= $10,000 (Currency Transaction Report - CTR required)
- **Structuring (Smurfing)**: Multiple transactions just below reporting threshold
- **Velocity Rules**: Unusual frequency of transactions in short time period
- **Geographic Anomalies**: Transactions involving high-risk jurisdictions
- **Counterparty Risk**: Transactions with sanctioned entities or high-risk counterparties
- **Behavioral Anomalies**: Transactions inconsistent with customer profile

7.2 Alert Handling

Priority 1 (Immediate): Sanctions hits, OFAC matches -> Freeze and report within 24 hours
Priority 2 (Urgent): PEP red flags, large suspicious transactions -> Review within 48 hours
Priority 3 (Standard): Low-risk alerts -> Review within 5 business days

---

8. Suspicious Activity Reporting (SAR)

8.1 SAR Filing Obligations

Financial institutions must file a SAR when they know, suspect, or have reason to suspect that a transaction:

- Involves funds from illegal activity
- Is designed to evade reporting requirements
- Has no lawful purpose

Filing thresholds:

- US: >= $5,000 (FinCEN)
- UK: No minimum threshold (SOCA/NCA)
- EU: Varies by member state (typically ?10,000-?15,000)

8.2 Tipping-Off Prohibition

It is a criminal offense to inform the subject of a SAR filing that a report has been or may be filed. This prohibition is known as "tipping off."

---

9. KYC Refresh and Ongoing Monitoring

9.1 KYC Refresh Schedule

```
Risk Category  |  Refresh Frequency
Low Risk  |  Every 3 years
Medium Risk  |  Every 2 years
High Risk / PEP  |  Every 1 year
EDD Customers  |  Every 6 months
```

9.2 Trigger-Based Reviews

Mandatory re-KYC is required upon:

- Change in customer beneficial ownership
- Significant change in transaction patterns
- Customer becoming a PEP
- Customer appearing on sanctions list
- Customer flagged in adverse media
- Major changes in business model or structure

---

10. Digital KYC (eKYC)

10.1 eKYC Methods

Document Verification:

- OCR-based document reading
- NFC chip verification (for e-passports)
- Liveness detection (anti-spoofing)

Biometric Verification:

- Facial recognition against ID document
- Fingerprint matching (mobile banking)
- Voice biometrics (telephone banking)

Database Checks:

- Government database verification (Aadhaar in India, SSA in USA)
- Credit bureau checks
- Electoral roll verification

10.2 eKYC Risk Considerations

Non-face-to-face onboarding carries higher risk. Compensating controls include:

- Multi-factor authentication
- Liveness detection to prevent deepfake attacks
- Enhanced monitoring for first 12 months
- Lower transaction limits until identity strengthened

---

11. Beneficial Ownership (UBO) Identification

11.1 Definition

A Ultimate Beneficial Owner (UBO) is any natural person who:

- Directly or indirectly owns >= 25% of the entity's shares or voting rights
- Exercises control over the management of the entity by other means

11.2 UBO Verification Process

1. Request corporate structure documentation
2. Trace ownership through all intermediate entities
3. Identify all natural persons at the top of the ownership chain
4. Verify identity of each UBO using standard CIP process
5. Document and maintain UBO records
6. Screen all UBOs against sanctions and PEP lists

11.3 Shell Company Risk

Shell companies (no real operations, complex layered ownership) present elevated risk.
Apply EDD for all customers using complex holding structures in secrecy jurisdictions.

---

12. Regulatory Framework

12.1 Key Regulations

Global:

- FATF 40 Recommendations (international standard)
- Basel Committee on Banking Supervision guidelines

US:

- Bank Secrecy Act (BSA)
- USA PATRIOT Act
- Customer Due Diligence Rule (FinCEN 2016)

UK:

- Money Laundering Regulations 2017
- Proceeds of Crime Act (POCA) 2002

EU:

- 6th Anti-Money Laundering Directive (6AMLD)
- GDPR (data protection in KYC)

India:

- Prevention of Money Laundering Act (PMLA) 2002

- RBI KYC Master Direction 2016 (updated 2024)
- Aadhaar-based eKYC framework

---

13. Penalties for Non-Compliance

Financial institutions face severe consequences for KYC/AML failures:

- **Fines**: Billions of dollars (e.g., HSBC $1.9B, Deutsche Bank $630M)
- **Reputational damage**: Loss of correspondent banking relationships
- **Criminal prosecution**: Officers and directors can face imprisonment
- **License revocation**: Loss of banking license in severe cases
- **Deferred Prosecution Agreements (DPAs)**: Enhanced regulatory oversight

Notable enforcement actions:

- HSBC (2012): $1.92B fine for facilitating drug cartel transactions
- Standard Chartered (2019): $1.1B for sanctions violations
- Goldman Sachs (2020): $2.9B for 1MDB fraud
- Westpac (2020): AUD 1.3B for 23 million AML breaches

Document Classification: Internal - Compliance Department
Last Updated: Q1 2025 | Next Review: Q1 2026
Owner: Head of Financial Crime Compliance